

목 차

정보보안관리규정

제1장 총칙	1
1. 정보보안 개요	1
1.1 목적	1
1.2 적용범위	1
1.3 용어정의	1
1.4 역할과 책임	2
제2장 관리적 보안	3
1. 보안 조직	3
1.1 보안 조직 구성 및 관리 주체	3
1.2 보안협의체 운영	3
1.3 보안 조직도	4
1.4 보안 조직 업무 분장	5
2. 보안 서약서	7
2.1 관리 주체	7
2.2 임직원 서약 관리	7
2.3 제3자 (일반 용역, 외주 인원)	7
3. 보안 교육	7
3.1 전사 보안 교육	7
3.2 부서별 보안 교육	7
4. 퇴직자 관리	8
4.1 인사 담당 부서의 역할	8
4.2 부서 보안책임자의 역할	8
4.3 임직원 준수 사항	8
4.4 기술 및 물리 보안 담당자의 역할	8
5. 보안 위반자 관리	9
5.1 위반 조치 및 징계	9
5.2 임직원 의무	9
5.3 위반 경중 판단 기준	9
6. 정보 자산 분류 및 관리	10
6.1 분류 주체 및 주기	10
6.2 정보 자산의 구분	10
6.3 정보 자산의 관리	10
7. 영업비밀 관리 기준	11
7.1 보관, 이관 및 반출	11

7.2 파기 절차	11
8. 준거성	12
9. 보안 점검	12
9.1 목적	12
9.2 시행 주체 및 주기	12
9.3 점검 대상 및 시행	12
제3장 물리적 보안	13
1. 보호구역 설정 및 관리	13
1.1 보호구역의 정의	13
1.2 보호구역의 지정 및 해제	13
1.3 보호구역 표시	13
1.4 출입 및 출입증 운영	14
2. 자산 반출·입 통제	15
2.1 통제 항목 분류	15
2.2 반출·입 관리 절차	15
3. CCTV 운영 및 시설 감시	16
3.1 운영 원칙	16
3.2 관리 및 정보 처리	16
4. 업무연속성 관리	17
4.1 비상시 보안 대책	17
제4장 기술적 보안	18
1. 사용자 단말기 보안	18
1.1 목적 및 적용 범위	18
1.2 단말기 관리 지침	18
1.3 네트워크 및 외부 전송 보안	18
2. 네트워크 보안	19
2.1 목적 및 적용 범위	19
2.2 네트워크 구성 및 접근 통제	19
2.3 무선 통신 및 장비 관리	19
3. 시스템 보안	20
3.1 목적 및 적용 범위	20
3.2 시스템 도입 및 계정 관리	20
3.3 개발 및 데이터 보안	21
4. 보안 시스템 운영	22
4.1 목적 및 적용 범위	22
4.2 운영 관리 체계	22
4.3 로그 관리 및 점검	22
5. IT 보안 사고 관리	23
5.1 목적 및 적용 범위	23

5.2 사고 대응 및 보고	23
5.3 사후 조치 및 재발 방지	23
제5장 관리보안 - 개인정보 보호지침	24
1. 개요	24
1.1 목적	24
1.2 적용범위	24
1.3 용어 정의	24
2. 개인정보 보호책임자의 의무와 책임	26
2.1 개인정보 보호책임자 지정	26
2.2 개인정보 보호책임자의 의무와 책임	26
2.3 개인정보취급자의 범위 및 의무와 책임	26
2.4 개인정보 취급 및 시스템 현황 관리	27
3. 개인정보의 안전성 확보조치	28
3.1 개인정보취급자 접근통제 및 인증	28
3.2 개인정보의 암호화	28
3.3 접속기록의 위변조 방지	28
3.4 보안프로그램의 설치 및 운영	28
3.5 개인정보처리시스템 보안	29
3.6 물리적 접근제한	29
3.7 출력 및 복사 시 보호조치	29
3.8 정보보호책임자의 의무와 책임	29
4. 정보보호 교육 및 정기 감사	30
4.1 개인정보보호 교육	30
4.2 정기 점검의 시행	30
5. 별첨 (양식)	31
5.1 개인정보 취급자 관리대장	31
5.2 개인정보처리시스템 현황대장	32
제6장 관리보안 - 사용자 보안지침	33
1. 개요	33
1.1 목적	33
1.2 적용 범위	33
1.3 책임 및 권한	33
2. 사용자 윤리	34
3. PC 및 단말기 보안	35
3.1 PC 보안 관리	35
3.2 패스워드 및 화면 보호기	35
3.3 공유 폴더 및 패치 관리	35
3.4 공용 PC 관리	35
4. 소프트웨어 및 인터넷 보안	36

4.1 소프트웨어 사용 지침	36
4.2 인터넷 보안 준수 사항	36
5. 모바일 및 전자메일 보안	37
5.1 모바일 기기 보안	37
5.2 전자메일 보안	37
5.3 대용량 파일 송수신 통제 절차	37
6. 정보 자산 및 저장매체 관리	38
6.1 정보 자산 보호 및 등급 분류	38
6.2 이동형 저장매체 관리	38
7. 업무 환경 보안 (Clean Desk)	38
제7장 물리보안 - 시설보호 및 출입통제 지침	39
1. 개요	39
1.1 목적	39
1.2 적용 범위 및 관리 주체	39
1.3 용어 정의	39
2. 보호구역의 설정	40
2.1 보호구역의 등급 정의	40
2.2 보호구역의 지정 기준	40
2.3 보호구역의 표시 규격	40
3. 보호구역의 관리 및 프로세스	41
3.1 출입 통제 수단 적용	41
3.2 지정 및 해제 절차	41
3.3 정기 점검	41
3.4 보호구역 내 촬영 및 자산 반출입 제한	41
4. 인원 출입 관리 절차	42
4.1 임직원	42
4.2 외부인 (방문객)	42
4.2.1 방문객 유형 분류	42
4.2.2 출입 단계별 세부 프로세스	42
4.2.3 방문객 출입 기록 및 이력 관리	42
4.2.4 야간 및 공휴일 방문 기준	43
4.2.5 반입 금지 물품 관리	43
5. 출입증 및 권한 관리 절차	43
5.1 출입증 관리	43
5.2 퇴직자 권한 회수 및 삭제	43
6. 차량 출입 관리 절차	44
6.1 차량 분류 및 출입 허용 기준	44
6.2 차량 출입 단계별 세부 절차	44
6.3 야간 및 공휴일 차량 출입 기준	45

6.4 차량 내 반입 금지 물품 관리	45
6.5 출입 이력 및 기록 관리	45
6.6 비상 상황 대응 절차	45
7. 위반 사항 처리	46
8. 별첨 (양식)	47
8.1 보호구역 현황 대장	47
8.2 외부방문자 개인정보 수집·이용 동의서	48
8.3 시설관리 경비원 근무수칙	49
8.4 통행차량 등록 신청서	50
제8장 물리보안 - CCTV운영 및 시설감시 지침	52
1. 개요	52
1.1 목적	52
1.2 적용 범위	52
1.3 용어 정의	52
2. 운영 방침	53
2.1 시설 감시 기본 원칙	53
2.2 CCTV 운영 기본 방침	53
2.3 CCTV 설치 및 구역별 세부 기준	53
2.4 관리 체계 및 책임	54
2.5 수집 및 보관	54
2.6 보관 장소 및 구역 보호	54
2.7 정보의 파기 기준 및 절차	55
2.8 정보의 열람 및 제공 기준과 절차	55
2.9 비밀유지 의무	56
2.10 시스템 관리 및 정기 점검	56
2.11 CCTV 설치배치도 관리	57
2.12 영상정보 보호조치 세부사항	57
3. 별첨 (양식 및 배치도)	58
3.1 영상정보 열람 신청서	58
3.2 CCTV 운영·점검일지	59
3.3 CCTV 설치배치도	60
3.4 CCTV 설치현황	61
3.5 법규준수 점검표	62
제9장 물리보안 - 정보자산 반출입 통제 지침	63
1. 개요	63
1.1 목적	63
1.2 적용 범위	63
1.3 용어 정의	63
2. 자산 반출·입 관리 절차	64

2.1 자산 유형 분류 및 통제 기준	64
2.2 반출입 프로세스 (6단계)	64
2.3 데이터 보안 및 파기	65
2.4 기록 관리	65
2.5 야간 및 공휴일 반출입 기준	65
3. 반출·입 금지 및 제한 항목	66
4. 비상 상황 대응	66
5. 사고 조치	66
6. 별첨 (양식)	67
6.1 전산장비 반출입 신청 및 확인서	67
제10장 기술보안 - 모바일 보안 지침	68
1. 개요	68
1.1 목적	68
1.2 적용 범위	68
1.3 용어 정의	68
2. 모바일 업무의 정보자산 분류 및 도입 타당성 검토	69
2.1 정보자산분류 및 등급 관리	69
2.2 모바일 업무 허용 기준	69
2.3 업무 도입 타당성 검토 항목	69
3. 모바일 기기 활용 및 관리	70
3.1 회사 지급 기기	70
3.2 개인 소유 기기 (BYOD 정책)	70
4. 인프라 및 앱 보안 보호	71
4.1 네트워크 및 접속 보호	71
4.2 모바일 앱 보안 통제	71
5. 모바일 기기 보안 기술 표준	72
5.1 공통 보안 및 관리 표준	72
5.2 OS별 보안 기술 상세 표준	72
6. 사용자 보안 준수 사항 (임직원 의무)	73
6.1 임직원 준수사항	73
7. 이동형 저장매체 관리	74
7.1 관리 원칙 및 신청 절차	74
7.2 사용 및 데이터 보호 통제	74
7.3 폐기 및 재사용 절차	74
제11장 기술보안 - 네트워크 보안 지침	75
1. 개요	75
1.1 목적	75
1.2 적용 범위	75
1.3 용어 정의	75

2. 책임 및 권한	76
2.1 전사보안책임자 (CSO)	76
2.2 기술보안담당자	76
2.3 네트워크 운영담당자	76
3. 네트워크 시스템 운영	77
3.1 시스템 도입 및 설치	77
3.2 시스템 보안 설정	77
3.3 시스템 운영 및 관리	78
3.4 시스템 폐기	78
4. 네트워크 접근 및 보안 통제	79
4.1 연결 및 변경 승인	79
4.2 구성 정보 보안	79
4.3 소프트웨어 보안 관리	79
4.4 네트워크 접근 통제	79
4.5 로그 관리	80
5. 별첨 (신청서 및 구성도)	81
5.1 네트워크 접속 권한 신청서	81
5.2 서버통신렉 및 네트워크 구성 현황	82
제12장 기술보안 - 시스템 보안 지침	84
1. 개요	84
1.1 목적	84
1.2 적용 범위	84
1.3 용어 정의	84
1.4 책임 및 권한	85
2. 시스템 도입 및 운영 절차	86
2.1 도입 및 설치	86
2.2 운영 및 관리	86
2.3 폐기 절차	86
3. 시스템 보안 설정	87
3.1 설치 시 보안 설정	87
3.2 운영 시 보안 통제	87
3.3 사용자 계정 관리	88
3.4 패스워드 관리 정책	88
3.5 변경 통제	89
3.6 백업 및 유지보수	89
3.7 성능 및 보안 패치	89
3.8 자산 반출입 및 용도 변경	90
3.9 서버 및 DB 접근통제	90
3.10 저장장치 파기 운영 절차	91

4. 별첨 (양식)	92
4.1 IT 시스템사용(변경) 신청서	92
4.2 저장장치 파기(확인) 대장	93
제13장 기술보안 - 보안시스템 운영 지침	94
1. 개요	94
1.1 목적	94
1.2 적용 범위	94
1.3 용어 정의	94
1.4 책임 및 권한	95
2. 보안시스템 구성	96
2.1 일반 구성 원칙	96
2.2 정책관리서버 구성	96
2.3 보안 에이전트 구성	96
3. 보안시스템 설치	96
3.1 물리적 설치 위치	96
3.2 논리적 설치 위치	96
4. 보안시스템 정책 관리	97
4.1 최초 정책 수립 절차	97
4.2 정책 변경 및 수정	97
4.3 정책 변경 이력 관리	97
4.4 보안 정책 점검 및 협의체 운영	97
5. 시스템 자체 보안 관리	98
5.1 시스템 운영 계정 관리	98
5.2 시스템 운영 및 유지보수	98
5.3 시스템 폐기 절차	98
5.4 시스템 업그레이드	98
5.5 로그 기록 및 감사 추적	99
6. 별첨 (사용자 매뉴얼)	100
제14장 기술보안 - 보안사고 대응 지침	101
1. 개요	101
1.1 목적	101
1.2 적용 범위	101
1.3 용어 정의	101
1.4 책임 및 권한	102
2. 보안사고 예방	102
2.1 시스템 보안성 검토	102
2.2 취약점 점검 및 조치	102
3. 보안사고 감지 및 대응	103
3.1 보안사고 감지	103

3.2 보안사고 대응 절차	103
4. 보안사고 처리 및 사후조치	104
4.1 사고 처리 후 점검 사항	104
4.2 사후 조치 및 재발 방지	104
5. 별첨 (구성도)	105
장애대응 매뉴얼/절차서	105
장애복구 훈련 매뉴얼/절차서	105
서버통신렉 및 네트워크 구성 현황	106